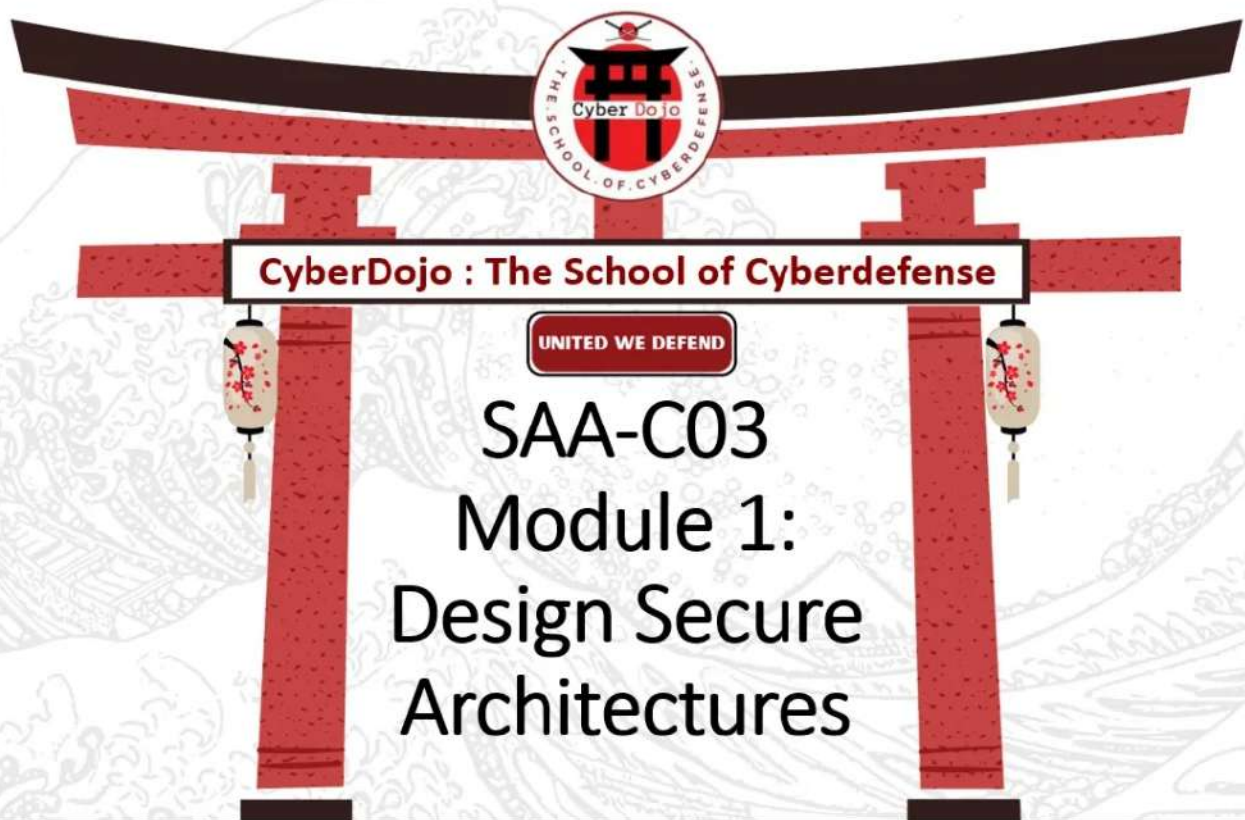
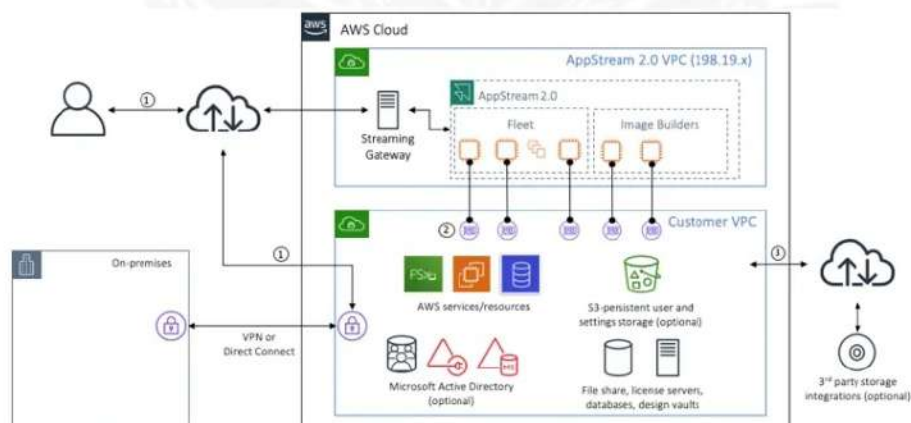




SAA-C03
Module 1:
Design Secure
Architectures

Module 1: Design Secure Architectures

- Section 1.1: Securing Access to AWS Resources
- Section 1.2: Securing Workloads and Applications
- Section 1.3: Determining Data Security Controls



SAA-C03

Securing Access to AWS Resources

- **Module 1:** Design Secure Architectures (30% of exam)
- **Section 1.1:** Securing Access to AWS Resources
- **Topics Covered:**
 - Shared Responsibility Model
 - IAM (Users, Groups, Roles, Policies)
 - Least Privilege Principle
 - AWS Organizations & SCPs
 - AWS Control Tower
 - Federated Access



SAA-C03

Shared Responsibility Model - DEEP DIVE

Responsibility	AWS's Job	Customer's Job
Physical Infrastructure	✓ Data centers, hardware, cables	✗
Hypervisor	✓ Virtualization layer	✗
Network Infrastructure	✓ Routers, switches, firewalls	✗
Host OS / Virtualization	✓ For managed services (RDS, etc.)	⚠ For EC2 (you manage guest OS)
Platform/Applications	⚠ For managed services	✓ For EC2-hosted apps
Data (at rest, in transit)	✗	✓ YOU encrypt your data
IAM (Users, Policies)	✗	✓ YOU manage who accesses what
Security Groups / NACLs	✗	✓ YOU configure firewalls

SAA Exam Focus:

•**For EC2:** You manage OS, applications, data, IAM, firewalls

•**For RDS:** AWS manages OS, patching, backups; you manage data, schema, IAM

•**For Lambda:** AWS manages everything except your code and IAM

Common Wrong Answer: "AWS is responsible for patching my EC2 OS"
→ **FALSE!** That's YOUR job.



SAA-C03

IAM Overview - Users, Groups, Roles

- **IAM Users:**

- Individual identities (people or applications)
- Long-term credentials (password or access keys)
- By default: **NO permissions** (explicit grants only)

- **IAM Groups:**

- Collections of users
- Attach policies to groups, users inherit
- Cannot nest groups (users only, not groups)

- **IAM Roles:**

- **NO long-term credentials** (temporary via STS)
- Assumed by: EC2, Lambda, cross-account users, federated users
- **Key for SAA:** EC2 instances should NEVER have access keys

Real World Scenario:

- Lambda needs to write to DynamoDB → Create Lambda Execution Role

- EC2 needs to read from S3 → Create EC2 Instance Role

- User from another AWS account needs access → Cross-account Role



SAA-C03

IAM Policies Deep Dive

- Policy Structure (JSON):

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::my-bucket/*",
      "Condition": {
        "IpAddress": { "aws:SourceIp": "203.0.113.0/24" }
      }
    }
  ]
}
```

Element	What it does	Example
Version	Policy language version	Always "2012-10-17"
Effect	Allow or Deny	"Allow"
Action	API calls allowed/denied	"ec2:StartInstances"
Resource	Which resources	"arn:aws:s3:::my-bucket/*"
Condition	When it applies (optional)	"IpAddress": {...}



SAA-C03

IAM Policies Deep Dive

- **Policy Types:**

Type	Who creates	Use Case
AWS Managed	AWS	Common roles (ReadOnlyAccess, AdministratorAccess)
Customer Managed	You	Specific business requirements
Inline	You	Embedded in user/group/role (not recommended)

SAA Exam Focus:

- **Explicit DENY** overrides any ALLOW
- **Least Privilege** = give minimum permissions needed
- Use **IAM Access Analyzer** to identify unused permissions



SAA-C03

Principle of Least Privilege

- **Definition:** Grant only the permissions required to perform a task.
- **How to Implement:**
 - **Start with minimum permissions** (deny all by default)
 - **Monitor usage** (CloudTrail, IAM Access Analyzer)
 - **Refine policies** based on actual usage
 - **Review regularly** (remove unused permissions)
- **IAM Access Analyzer:**
 - Analyzes CloudTrail logs to see what permissions are actually used
 - Generates **least-privilege policies** based on real usage
 - Identifies unused roles/permissions

SAA Exam Scenario:

A developer needs to read objects from an S3 bucket and write logs to CloudWatch.
What permissions should you grant?

✓ CORRECT:

- s3:GetObject on the specific bucket
- logs:CreateLogGroup, logs:CreateLogStream, logs:PutLogEvents

✗ WRONG: s3:* (too broad)

✗ WRONG: AdministratorAccess (dangerous)



SAA-C03

Root User Best Practices

- **Best Practices (MEMORIZE for SAA):**

#	Best Practice	Why
1	Enable MFA	Non-negotiable first step
2	Never use for daily tasks	Create IAM admin user instead
3	Store credentials securely	Password manager, physical safe
4	Don't create access keys	Unless absolutely necessary
5	Use as break-glass only	Emergency access only

What Requires Root User (SAA scenarios):

- Changing account name or email
- Closing the account
- Changing support plan
- Enabling MFA delete on S3
- Viewing/downloading tax invoices

What DOES NOT require root (use IAM admin):

- Creating S3 buckets
- Launching EC2 instances
- Creating IAM users/roles/policies
- Configuring CloudTrail



SAA-C03

IAM Roles for EC2 - NO Access Keys!

- **Why never use access keys on EC2:**
 - Keys stored on instance (security risk)
 - Keys need rotation (operational overhead)
 - Keys are long-term credentials (harder to revoke)
- **CORRECT Way: IAM Instance Role**
 - Create IAM role with required permissions
 - Attach role to EC2 instance (at launch or modify)
 - EC2 retrieves **temporary credentials** via Instance Metadata Service (IMDS)
- **How EC2 uses role (simplified):**
 - Application → IMDS endpoint (169.254.169.254) → Temporary credentials → AWS Service
- **SAA Exam Focus:**
 - If you see "access keys on EC2" in an answer → **ELIMINATE** (wrong practice)
 - If you see "IAM role attached to EC2" → **CORRECT** approach



SAA-C03

Cross-Account Access using IAM Roles

- **Use Case:** Company has Account A (Production) and Account B (Development). Developers in Account B need to view CloudWatch logs in Account A.

- **Solution:** IAM Role with trust policy

- **Step 1: Create Role in Account A (Trusting Account)**

- {
- "Effect": "Allow",
- "Principal": { "AWS": "arn:aws:iam::ACCOUNT_B_ID:root" },
- "Action": "sts:AssumeRole"
- }

- **Step 2: Attach permissions policy to role**

- Example: CloudWatchReadOnlyAccess

Step 3: Users in Account B assume the role

Via AWS Console: Switch Role

Via CLI: `aws sts assume-role`

SAA Exam Focus:

Trust policy defines WHO can assume role (Principal)

Permissions policy defines WHAT they can do

STS (Security Token Service) issues temporary credentials

Real World Pattern:

Centralized logging account

All other accounts assume role to send logs

No sharing of access keys across accounts



SAA-C03

AWS Organizations - Centralized Management

- What is AWS Organizations?

- Central service to manage **multiple AWS accounts**
- Consolidated billing (single bill for all accounts)
- Hierarchical grouping with Organizational Units (OUs)

SAA Exam Focus:

- Organizations is FREE (only pay for underlying services)

Feature	Benefit
Consolidated Billing	Volume discounts across accounts
Service Control Policies (SCPs)	Central governance guardrails
Account Management	Create accounts programmatically
AWS Control Tower integration	Automated governance setup

- Consolidated billing = discounts across ALL accounts

- SCPs apply to **all users** in member accounts (including root)



SAA-C03

12

Service Control Policies (SCPs) Deep Dive

- What are SCPs?

- Central policies that define **maximum available permissions** for accounts in an OU
- Act as "guardrails" - you can't grant permissions SCPs deny

Aspect	SCP	IAM Policy
Scope	Account-level (affects ALL users/roles)	User/group/role-level
Effect	Defines maximum (can't go beyond)	Grants specific permissions
Deny only	Can only DENY (cannot ALLOW)	Can ALLOW or DENY
Root user	CAN be restricted by SCP	Cannot be restricted by IAM



SAA-C03

13

AWS Control Tower

- What is Control Tower?
- Automates setup of **well-architected, multi-account AWS environment**
- Uses AWS Organizations + SCPs + CloudFormation

Component	Purpose
Landing Zone	Well-architected baseline environment
Guardrails	Pre-packaged SCPs (mandatory vs. optional)
Account Factory	Automated account provisioning

- SAA Exam Focus:
 - Control Tower is for **automated governance setup**
 - Not required for Organizations (Organizations can work alone)
 - Use when you need pre-configured compliance guardrails
- Control Tower vs. Organizations:

Feature	Organizations	Control Tower
Setup	Manual	Automated landing zone
Guardrails	Custom SCPs	Pre-packaged + custom
Account creation	Manual or API	Account Factory
Best for	Simple multi-account	Enterprise governance



SAA-C03

Federated Access (AWS IAM Identity Center)

- What is Federation?
- Users log in with **existing corporate credentials** (Active Directory, Okta, etc.)
- No separate IAM users needed
- Temporary credentials via SAML 2.0 or OIDC
- **AWS IAM Identity Center (formerly AWS SSO):**
- Central place to manage access across multiple AWS accounts
- Integrates with Microsoft AD, Okta, Ping, etc.

Pattern	When to Use
SAML 2.0	Corporate AD, Okta, ADFS
OIDC	Web/mobile apps, CI/CD (GitHub Actions)
Cognito	Customer-facing apps (user pools)

- SAA Exam Focus:
 - Federation = NO IAM users for employees
 - Identity Center = AWS's managed federation service
 - Use when you have >100 employees needing AWS access
- Real World:
 - Company has 5000 employees already using Microsoft AD
 - Instead of creating 5000 IAM users, integrate AD with IAM Identity Center
 - Employees use same password + MFA for AWS



SAA-C03

Section 1.1 Summary

Concept	Key Takeaway
Shared Responsibility	AWS secures of cloud; you secure in cloud
IAM Roles	Use for EC2, Lambda, cross-account (NEVER access keys on instances)
Least Privilege	Start minimal, use IAM Access Analyzer to refine
Root User	Enable MFA, use only for account-level tasks
Organizations + SCPs	Central governance across multiple accounts
Control Tower	Automated landing zone with guardrails
Federation	Use corporate credentials, no IAM users needed

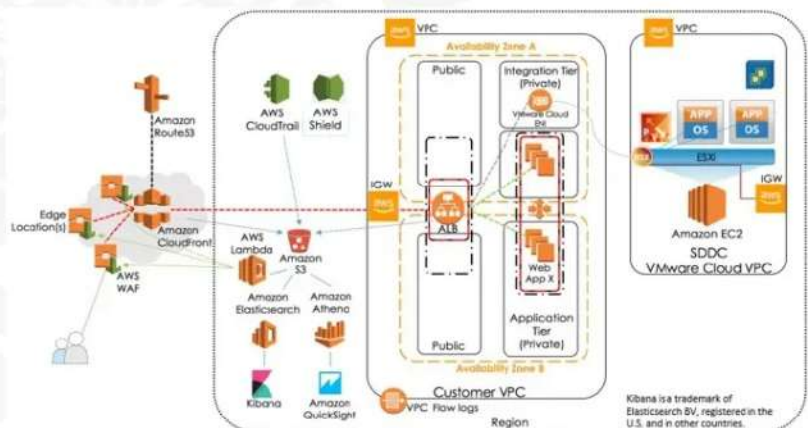


SAA-C03

16

Section 1.2: Securing Workloads and Applications

- Topics Covered:
 - VPC Fundamentals (CIDR, subnets, route tables)
 - Security Groups vs. Network ACLs
 - NAT Gateways & Instances
 - AWS WAF, Shield, Firewall Manager
 - VPN, Direct Connect, PrivateLink
 - AWS Certificate Manager (ACM)
 - AWS Secrets Manager



SAA-C03

17

VPC Fundamentals - CIDR, Subnets, Route Tables

- **VPC (Virtual Private Cloud):**
 - Logically isolated section of AWS cloud
 - Regional service (spans all AZs in a region)
 - You define IP address range (CIDR block)
- **CIDR Blocks (IPv4):**
 - VPC CIDR: /16 (e.g., 10.0.0.0/16 = 65,536 IPs)
 - Subnet CIDR: /24 to /28 (e.g., 10.0.1.0/24 = 256 IPs)
 - Reserved IPs: First 4 and last 1 IP in each subnet (AWS uses)
- **Subnets:**
- **Route Tables:**
 - Set of rules determining where traffic goes
 - Each subnet associated with ONE route table
 - Main route table (default) vs. custom route tables
- **SAA Exam Focus:**
 - Cannot change VPC CIDR after creation (plan ahead!)
 - Subnets cannot span AZs (each subnet in ONE AZ)
 - Internet Gateway is REGIONAL (one per VPC, serves all AZs)
- **Common Wrong Answer:** "Subnets can span multiple Availability Zones" → **FALSE!**

Type	Route to IGW?	Resources	Access
Public Subnet	✓ Yes (route 0.0.0.0/0 → IGW)	Web servers, load balancers	Internet-facing
Private Subnet	✗ No	App servers, databases	Internal only



SAA-C03

18

Security Groups - Stateful, Instance-level

- **Definition:** Virtual firewall controlling traffic for ENI/instance
- **SAA Exam Focus:**
 - Security Groups are **stateful** (unlike NACLs)
 - Can reference other Security Groups as source (not just IPs)
 - Changes apply **IMMEDIATELY** to all associated instances
- **Real World Example:**
 - Security Group A (Web-SG):
 - Inbound: Allow HTTP/HTTPS from 0.0.0.0/0
 - Security Group B (App-SG):
 - Inbound: Allow port 8080 from Web-SG (not IP addresses!)
 - This way, if Web-SG changes, App-SG automatically works.

Characteristic	Details
Scope	Instance-level (attached to ENI)
Stateful	✓ If inbound allowed, return outbound auto-allowed
Rules	ALLOW rules only (no explicit DENY)
Evaluation	All rules evaluated before decision
Default	ALL inbound DENIED, ALL outbound ALLOWED



SAA-C03

19

Security Groups - Stateful, Instance-level

- **Example Security Group Rules:**

Type	Protocol	Port	Source	Description
Inbound	TCP	22	203.0.113.0/24	SSH from corporate network
Inbound	TCP	443	0.0.0.0/0	HTTPS from anywhere
Outbound	All	All	0.0.0.0/0	All outbound traffic allowed



SAA-C03

Network ACLs (NACLs) - Stateless, Subnet-level

- **Definition:** Stateless firewall controlling traffic at subnet boundary

Characteristic	Security Group	NACL
Scope	Instance-level	Subnet-level
State	Stateful	Stateless
Rules	ALLOW only	ALLOW + DENY
Evaluation	All rules	Rule numbers (lowest to highest)
Default	ALL inbound DENY	Default NACL: ALLOW ALL
Custom	N/A	Custom NACL: DENY ALL



SAA-C03

Network ACLs (NACLs) - Stateless, Subnet-level

- **Rule Number Evaluation:**
 - Rule 100: Allow 10.0.0.0/16 (internal traffic)
 - Rule 200: Allow 203.0.113.0/24 (corporate)
 - Rule 300: Deny 0.0.0.0/0 (everything else)
 - Traffic from corporate IP → Matches rule 200 → ALLOWED
 - Traffic from malicious IP → No match until rule 300 → DENIED
- **Stateless Example (Common Trap):**
 - Inbound rule: Allow port 80 from 0.0.0.0/0
 - Outbound rule: Must ALSO allow ephemeral ports (1024-65535) for response
 - Without outbound rule → Response traffic blocked!
- **SAA Exam Focus:**
 - NACLs are **stateless** - need BOTH inbound and outbound rules
 - NACLs support **explicit DENY** (unlike SGs)
 - Rule numbers: AWS recommends spacing by 100 (100, 200, 300)



SAA-C03

22

Security Groups vs. NACLs - Comparison Table

Feature	Security Group	Network ACL
Level	Instance (ENI)	Subnet
State	Stateful	Stateless
Rules	Allow only	Allow + Deny
Rule order	All evaluated	Number order (lowest first)
Default	All inbound DENIED	Default: ALLOW ALL
Custom	N/A	Custom: DENY ALL
Attach to	EC2, ENI, ELB, RDS	Subnet
Targets	IPs, SGs, prefixes	IPs only
Logging	VPC Flow Logs only	VPC Flow Logs only



SAA-C03

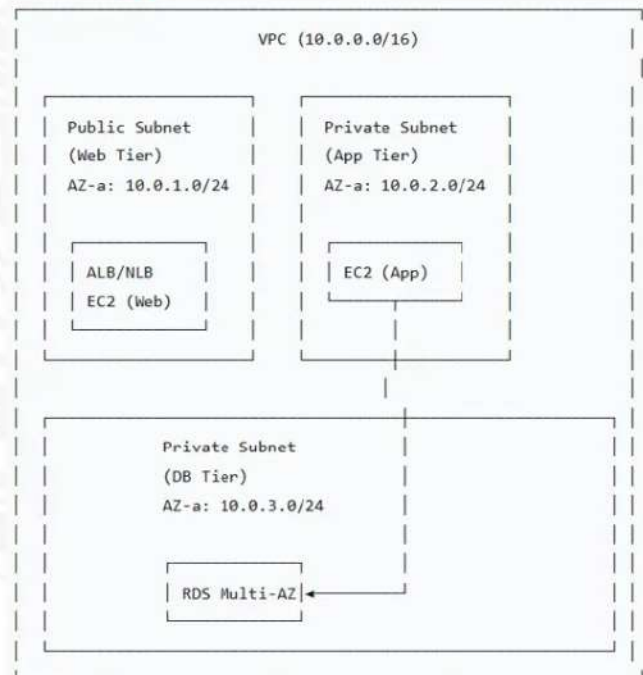
23

Public vs. Private Subnets - Design Patterns

Three-Tier Architecture (Standard SAA pattern):

- Internet → IGW → Public Subnet (Web Tier) → Private Subnet (App Tier) → Private Subnet (DB Tier)

Tier	Subnet	IGW Route	Security Group	NACL (optional)
Web	Public	✓ Yes	Allow 80/443 from 0.0.0.0/0	Default (allow all)
App	Private	✗ No	Allow port 8080 from Web-SG	Custom (deny direct internet)
DB	Private	✗ No	Allow port 3306 from App-SG	Custom (deny all except VPC)



SAA-C03

24

NAT Gateways & NAT Instances

NAT (Network Address Translation) Purpose:

- Allow private subnet instances to access internet (for updates, patches)
- Block internet from initiating connection to private instances

NAT Gateway (Managed, Recommended):

Feature	Details
Managed	✓ AWS handles availability and scaling
HA	✓ Within one AZ (deploy multiple for AZ resilience)
Bandwidth	Up to 45 Gbps (auto-scales)
Cost	~\$0.045/hour + data processing charges
Maintenance	None (AWS managed)

SAA Exam Focus:

- NAT Gateway is **ALWAYS** the answer (unless cost is primary concern for low traffic)
- NAT Gateway is AZ-specific (deploy in multiple AZs for HA)
- NAT Gateway requires Elastic IP (public IP)
- NAT Gateway is in **public subnet**

NAT Instance (Self-managed, Legacy):

Feature	Details
Managed	✗ You manage EC2 instance
HA	✗ You implement failover
Bandwidth	Depends on instance type
Cost	Cheaper for low throughput
Maintenance	You handle patches, OS updates



SAA-C03

25

AWS WAF - Web Application Firewall

- **Definition:** Layer 7 firewall protecting web applications from common exploits

- **What WAF Protects Against:**

Attack Type	Description	Example
SQL Injection	Malicious SQL in input fields	' OR '1'='1
XSS	Cross-site scripting	<script>alert(1)</script>
Rate-based rules	Too many requests from one IP	1000 requests/sec
Bad bots	Malicious automated traffic	Scrapers, attackers
Geo-blocking	Block specific countries	Block traffic from suspicious regions

- **WAF Integrations:**

Integration	Use Case
CloudFront	Global CDN protection
Application Load Balancer (ALB)	Regional web app protection
API Gateway	API endpoint protection



SAA-C03

AWS WAF - Web Application Firewall

- **WAF Rule Types:**

Rule Type	Description
AWS Managed Rules	Pre-built rules (e.g., AWSManagedRulesCommonRuleSet)
Customer Managed Rules	Your own custom rules
IP Sets	Block/allow specific IPs
Rate-based rules	Limit requests per IP (e.g., 100 per 5 minutes)

- **SAA Exam Focus:**

- WAF is Layer 7 (application layer)
- Shield is Layer 3/4 (network layer for DDoS)
- Use together: Shield for DDoS, WAF for web exploits

- **Real World Example:**

- Rate-based rule: Block IP if > 100 requests in 5 minutes
- Geo-match rule: Block all traffic from Country X
- SQL injection rule: Block requests with malicious SQL patterns



SAA-C03

AWS Shield - DDoS Protection

Feature	Shield Standard	Shield Advanced
Cost	✓ FREE	💰 Paid (~\$3,000/month)
Protection	Common DDoS attacks	Sophisticated DDoS attacks
Coverage	All AWS customers	Business-critical apps
DRT access	✗ No	✓ 24/7 DDoS Response Team
Cost protection	✗ No	✓ For scaling during attacks
Integration	Basic	CloudFront, Route 53, ELB, Global Accelerator



SAA-C03

AWS Shield - DDoS Protection

- **What Shield Standard Protects Against:**
 - SYN floods
 - UDP reflection attacks
 - HTTP flood (basic)
- **What Shield Advanced Adds:**
 - Application-layer DDoS (advanced)
 - Dedicated support
 - Financial protection (costs from scaling)
 - Real-time metrics
- **SAA Exam Focus:**
 - **Shield Standard** is automatically enabled for ALL customers
 - **Shield Advanced** is for business-critical applications
 - Shield + WAF = Comprehensive protection
 - DDoS Response Team (DRT) is ONLY with Shield Advanced
- **When to use Shield Advanced:**
 - Business-critical applications
 - Previous DDoS attacks experienced
 - Compliance requirements
 - Need cost protection for auto-scaling



SAA-C03

AWS Firewall Manager - Centralized Security Management

- **Definition:** Central service to configure and manage firewall rules across multiple AWS accounts and resources
- **What Firewall Manager Manages:**

Resource	What it manages
AWS WAF rules	Across all accounts in Organizations
AWS Shield Advanced	Enable for all accounts
Security Groups	Common baseline rules
Network Firewall	VPC-level protection

- **SAA Exam Focus:**
 - Firewall Manager requires **AWS Organizations**
 - Use when you have >1 account to manage
 - Automatically protects new accounts
- **Real World:**
 - Company has 50 AWS accounts (dev, test, prod for 10 teams)
 - Firewall Manager ensures:
 - All accounts have same WAF rules
 - All new accounts get Shield Advanced
 - No account can remove security group rules

Service	Scope	Purpose
WAF	Single account, single resource	Web app protection
Shield Advanced	Single account	DDoS protection
Firewall Manager	Multiple accounts (Organizations)	Centralized policy management

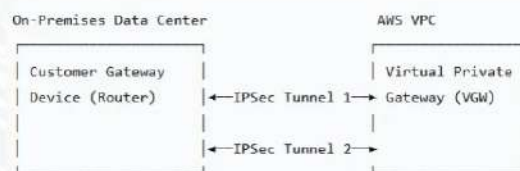


SAA-C03

30

Site-to-Site VPN - Secure Connection

- **Definition:** Encrypted connection between on-premises network and AWS VPC over public internet
- **SAA Exam Focus:**
 - VPN = Fast setup, lower cost, public internet
 - Two tunnels = Automatic failover
 - For higher HA, use Direct Connect + VPN as backup
- **When to use VPN:**
 - Quick, temporary connection
 - Low-to-medium bandwidth needs
 - Budget-conscious
 - Backup for Direct Connect



Component	Description
Virtual Private Gateway (VGW)	AWS-side VPN concentrator (attached to VPC)
Customer Gateway (CGW)	On-premises VPN device representation
VPN Connection	Two IPsec tunnels (for HA)



SAA-C03

31

AWS Direct Connect - Dedicated Private Connection

- **Definition:** Dedicated, private network connection from on-premises to AWS (bypasses public internet)
- **Connection Types:**

Type	Speed	Use Case
Dedicated Connection	1 Gbps, 10 Gbps, 100 Gbps	High bandwidth, predictable
Hosted Connection	50 Mbps to 10 Gbps	Partner-provided, smaller scale

Virtual Interfaces (VIFs):

VIF Type	Purpose	Traffic
Private VIF	Connect to VPC resources	Private IPs, stays on AWS network
Public VIF	Connect to AWS public services (S3, DynamoDB)	Public IPs, AWS backbone
Transit VIF	Connect to Transit Gateway	Multiple VPCs



SAA-C03

32

AWS Direct Connect - Dedicated Private Connection

- **Direct Connect vs. VPN:**

Feature	Direct Connect	VPN
Network	Private AWS backbone	Public internet
Latency	Consistent	Variable
Bandwidth	Up to 100 Gbps	Limited by internet
Cost	Higher	Lower
Setup time	Weeks (need carrier)	Minutes
Security	Physically private	Encrypted over internet



SAA-C03

33

AWS Direct Connect - Dedicated Private Connection

- **SAA Exam Focus:**

- Direct Connect does NOT provide encryption (use VPN or TLS on top)
- Use for: large data transfers, hybrid cloud, low latency
- For DR: Direct Connect + VPN backup

- **Real World:**

- Financial company needs consistent 10 Gbps connection:
- - Primary: Direct Connect (10 Gbps, dedicated)
- - Backup: Site-to-Site VPN (over secondary internet)



SAA-C03

34

AWS PrivateLink - Private Service Access

- **Definition:** Allows you to access services over AWS network without using public internet

VPC Endpoint Types:

Use Case	Description
Access AWS services	S3, DynamoDB, etc. from VPC (alternative to Gateway Endpoint)
Access your own services	Expose your application as a service to other VPCs
Access SaaS partners	Connect to third-party services (Datadog, Snowflake, etc.)

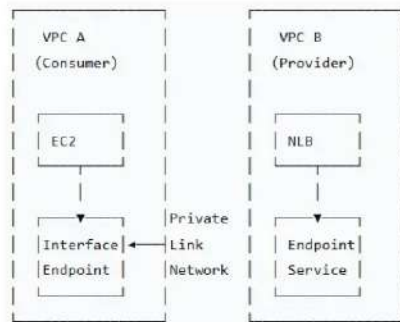
Type	Services	Cost	Traffic
Gateway Endpoint	S3, DynamoDB only	FREE	Sits in route table
Interface Endpoint	All other services	\$0.01/hr + data	ENI in subnet (PrivateLink)



SAA-C03

35

AWS PrivateLink - Private Service Access



• SAA Exam Focus:

- **Gateway Endpoint** is FREE (use for S3/DynamoDB when possible!)
- **PrivateLink** = Interface Endpoint (costs money)
- Use PrivateLink when you need to expose your own service to other VPCs

• Common Exam Pattern:

- Question: "VPC needs to access S3 without internet"
- ☒ **CORRECT:** Gateway Endpoint (free)
- ☒ **WRONG:** NAT Gateway (costs, goes to internet)
- ☒ **WRONG:** Interface Endpoint (costs, unnecessary for S3)



SAA-C03

36

AWS Certificate Manager (ACM) - SSL/TLS Certificates

- **Definition:** Service to provision, manage, and deploy public and private SSL/TLS certificates

Feature	Details
Free	☒ Public certificates are FREE (no cost)
Automatic renewal	AWS handles renewal automatically
Integration	ALB, CloudFront, API Gateway, NLB (with TLS listeners)

• What ACM Does NOT Support:

- ☒ EC2 instances (install manually)
- ☒ On-premises servers
- ☒ Certificates for non-AWS resources

• Certificate Types:

Type	Use Case	Cost
Public	Internet-facing applications	FREE
Private	Internal applications	Pay for Private CA



SAA-C03

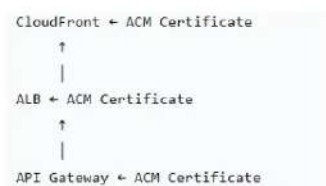
37

AWS Certificate Manager (ACM) - SSL/TLS Certificates

• SAA Exam Focus:

- ACM certificates are **FREE** for AWS services
- Cannot extract private key (AWS manages it)
- Automatic renewal is a key benefit
- For EC2, you must purchase/install certificates yourself

• ACM Integration:



SAA-C03

38

AWS Secrets Manager - Credential Management

- **Definition:** Service to securely store, manage, and rotate secrets (passwords, API keys, database credentials)
- **Key Features:**

Feature	Benefit
Automatic rotation	Built-in rotation for RDS, Redshift, DocumentDB
Encryption	Integrates with KMS
Access control	Fine-grained IAM policies
Auditing	CloudTrail integration

Secrets Manager vs. Systems Manager Parameter Store:

Feature	Secrets Manager	Parameter Store
Cost	\$0.40 per secret/month	FREE up to 10,000 params
Rotation	✓ Built-in	✗ Manual (via Lambda)
Use case	Database passwords, API keys	Configuration data, non-sensitive
Retrieval	API call	API call



SAA-C03

39

AWS Secrets Manager - Credential Management

- **RDS Integration Example:**
 - Application → Secrets Manager API → Get credentials → Connect to RDS
- Secrets Manager automatically:
 - 1. Generates random password for RDS
 - 2. Rotates password every X days
 - 3. Updates RDS with new password
 - 4. Application gets new credentials automatically
- **SAA Exam Focus:**
 - Use Secrets Manager for **rotating credentials**
 - Use Parameter Store for **configuration** (cheaper)
 - Never hardcode credentials in code or config files
- **Real World:**
 - ✓ CORRECT: Application calls Secrets Manager to get DB password
 - ✗ WRONG: DB password stored in environment variables
 - ✗ WRONG: DB password in application.properties file



SAA-C03

40

Section 1.2 Summary - Securing Workloads

Service	Purpose	Key Takeaway
Security Group	Instance-level firewall	Stateful, allow only
NACL	Subnet-level firewall	Stateless, allow+deny
NAT Gateway	Private subnet internet access	Managed, AZ-specific
WAF	Web app protection	Layer 7, SQL injection, XSS
Shield	DDoS protection	Standard = free, Advanced = paid
Firewall Manager	Centralized security	Requires Organizations
VPN	Encrypted connection	Public internet, fast setup
Direct Connect	Dedicated connection	Private, consistent, slower setup
PrivateLink	Private service access	Use Gateway Endpoint for S3 (free)
ACM	SSL/TLS certificates	FREE for AWS services
Secrets Manager	Credential management	Automatic rotation



SAA-C03

41

Section 1.3: Determining Data Security Controls

• Topics Covered:

- Encryption at Rest (SSE-S3, SSE-KMS, SSE-C, EBS, RDS)
- AWS KMS (Key Management Service)
- Encryption in Transit (TLS/SSL, ACM)
- Amazon Macie (PII Detection)
- AWS Config (Compliance Monitoring)
- AWS Audit Manager
- Data Lifecycle & Retention Policies



SAA-C03

42

Encryption at Rest - Overview

• What is Encryption at Rest?

- Data is encrypted when stored on disk
- Protects against physical theft, unauthorized disk access
- AWS provides multiple encryption options

Where Encryption at Rest Applies:

Service	Encryption Method
S3	SSE-S3, SSE-KMS, SSE-C, Client-side
EBS	Default encryption (KMS)
RDS	KMS encryption
DynamoDB	Default encryption (AWS owned or KMS)
EFS	KMS encryption

Three SSE Options for S3 (MEMORIZE):

Option	Who manages keys	Who encrypts	Key rotation	Cost
SSE-S3	AWS	AWS	AWS-managed	Free
SSE-KMS	AWS KMS (you control)	AWS	You control	KMS costs
SSE-C	You	AWS	You manage	Free (but you manage keys)



SAA-C03

43

AWS KMS (Key Management Service) - Deep Dive

- **Definition:** Managed service to create and control encryption keys

• Key Types:

Key Type	Description	Cost
AWS Managed Keys	AWS creates and manages (aws/s3, aws/ebs, etc.)	Free
Customer Managed Keys (CMK)	You create and manage	\$1/month per key
Custom Key Store	CloudHSM-backed keys	Additional costs

Key Features:

Feature	Benefit
Key Policies	Control who can use/manage keys
Key Rotation	Automatic (1 year) or manual
Auditing	CloudTrail logs every key usage
Integration	Works with 100+ AWS services



SAA-C03

44

AWS KMS (Key Management Service) - Deep Dive

SAA Exam Focus:

• KMS Key Policies Example:

```
{
  "Effect": "Allow",
  "Principal": { "AWS": "arn:aws:iam::123456789012:role/MyRole" },
  "Action": [
    "kms:Encrypt",
    "kms:Decrypt",
    "kms:GenerateDataKey"
  ],
  "Resource": "*"
}
```

- KMS keys are **REGIONAL** (not global)
- Cannot extract plaintext of KMS keys (AWS manages them)
- Use **GenerateDataKey** for envelope encryption (encrypt large data)

Envelope Encryption Pattern:

1. GenerateDataKey → Returns Plaintext Key + Encrypted Key
2. Encrypt large data with Plaintext Key
3. Discard Plaintext Key (keep Encrypted Key)
4. Store Encrypted Key with encrypted data



SAA-C03

45

Encryption in Transit (TLS/SSL)

- **Definition:** Data encrypted while moving between client and server or between services
- **AWS Encryption in Transit Options:**

Option	Use Case
TLS/SSL	HTTPS for web traffic
ACM Certificates	Load balancers, CloudFront
VPN	Site-to-Site encrypted tunnels
Direct Connect + VPN	Encrypted dedicated connection

Where to Enforce HTTPS:

Service	How to Enforce
CloudFront	Viewer Protocol Policy: Redirect HTTP to HTTPS
ALB	Listener rule: Redirect HTTP:80 to HTTPS:443
S3	Bucket policy: Deny HTTP requests
API Gateway	Custom domain with TLS



SAA-C03

46

Amazon Macie - Discovering Sensitive Data

- **Definition:** Fully managed service to discover, classify, and protect sensitive data (PII) in S3
- **What Macie Detects:**

Data Type	Examples
Personally Identifiable Information (PII)	SSN, passport numbers, driver's license
Financial data	Credit card numbers, bank accounts
Healthcare data	Medical record numbers, insurance IDs
Credentials	API keys, passwords

• What Macie Detects:

1. Macie scans S3 buckets
2. Uses ML to identify sensitive data patterns
3. Creates findings with severity levels
4. Integrates with Security Hub and EventBridge
5. Automates remediation (e.g., S3 bucket policy changes)

• SAA Exam Focus:

- Macie = **S3 data classification** (not access control)
- Not for scanning databases (use other tools)
- Integrates with Security Hub for centralized findings



SAA-C03

47

AWS Config - Resource Compliance Monitoring

Definition: Service that evaluates, audits, and tracks resource configurations against desired policies

Key Features:

Feature	Description
Configuration history	Timeline of resource changes
Config Rules	Evaluate resources against best practices
Compliance dashboard	Visualize compliance status
Remediation actions	Automatic or manual fixes

Config vs. CloudTrail vs. CloudWatch:

Service	What it does
Config	What resources ARE (configuration state)
CloudTrail	Who did what (API activity)
CloudWatch	How resources ARE PERFORMING (metrics)

• **SAA Exam Focus:**

- Config = **Configuration compliance** over time
- Config Rules = Evaluate against desired state
- Can auto-remediate non-compliant resources



SAA-C03

48

AWS Audit Manager - Automated Evidence Collection

Definition: Service to continuously audit AWS usage and collect evidence for compliance frameworks

How Audit Manager Works:

1. Select framework (e.g., PCI DSS)
2. Audit Manager automatically:
 - Maps controls to AWS resources
 - Collects evidence (Config, CloudTrail, etc.)
 - Creates assessment reports
3. Download report for auditor

Audit Manager vs. Config vs. Artifact:

Service	Purpose
Config	Resource compliance (technical)
Artifact	View AWS compliance reports (SOC, PCI)
Audit Manager	Automate YOUR compliance evidence collection

• **SAA Exam Focus:**

- Audit Manager = **Evidence collection** for YOUR compliance
- Artifact = AWS's compliance reports (view only)
- Use when auditor needs proof of controls



SAA-C03

49

Data Lifecycle & Retention Policies

S3 Lifecycle Policies (MEMORIZE for SAA):

Policy Type	Action	Example
Transition	Move to cheaper storage class	Standard → IA after 30 days
Expiration	Delete objects	Delete logs after 365 days

• **SAA Exam Focus:**

- Lifecycle policies = **Cost optimization** (move old data to cheaper tiers)
- Object Lock = **Compliance** (financial, medical records)
- Transition vs. Expiration - know the difference

Common Lifecycle Pattern:

Day 0-30: S3 Standard (frequent access)
Day 31-90: S3 Standard-IA (infrequent access)
Day 91-365: S3 Glacier (archive)
After day 365: Expire (delete)

Other Retention Features:

Feature	Service	Purpose
Object Lock	S3	WORM (Write Once Read Many) for compliance
Retention Period	S3	Prevent deletion for fixed period
Legal Hold	S3	Prevent deletion until removed
Snapshot retention	EBS, RDS	Automated snapshot lifecycle



SAA-C03

50

Data Security Controls - Quick Reference

Requirement	AWS Service	Key Feature
Encrypt S3 objects	SSE-S3, SSE-KMS, SSE-C	Server-side encryption
Control encryption keys	KMS	Customer managed keys
Enforce HTTPS	S3 bucket policy, CloudFront	aws:SecureTransport condition
Find PII in S3	Macie	Automated data classification
Resource compliance	Config	Config rules + remediation
Audit evidence	Audit Manager	Automated compliance reports
Data retention	S3 Lifecycle	Transition + expiration
WORM compliance	S3 Object Lock	Prevent deletion/modification



SAA-C03

51

Lab/Hands-on Guide - Encryption & Compliance

Lab 1: Enable S3 Default Encryption with KMS

1. Create KMS key (Customer Managed)
2. Configure S3 bucket: Default encryption → KMS
3. Upload test file → Verify encrypted
4. Check CloudTrail for kms:GenerateDataKey calls

Lab 2: Create Config Rule for Encrypted Volumes

1. AWS Config → Rules → Add rule
2. Search: ec2-encrypted-volumes
3. Apply to region
4. Check compliance status

Lab 3: Macie Discovery Job

1. Enable Macie
2. Create S3 bucket with sample sensitive data
 - CSV with fake credit card numbers
3. Create discovery job
4. Review findings

Lab 4: S3 Lifecycle Policy

1. Create S3 bucket
2. Add lifecycle rule:
 - Transition to Standard-IA: 30 days
 - Transition to Glacier: 90 days
 - Expire: 365 days
3. Upload file and verify (wait or use CLI)



SAA-C03

52

Section 1.3 Summary

Service	Purpose	Key Exam Point
SSE-S3	S3 encryption	AWS manages keys (free)
SSE-KMS	S3 encryption	You control keys (costs \$)
SSE-C	S3 encryption	You provide keys (free but manage)
KMS	Key management	Regional, \$1/month per CMK
Macie	Find PII in S3	Data classification (not access control)
Config	Resource compliance	Configuration history + rules
Audit Manager	Evidence collection	Automated compliance reports
S3 Lifecycle	Data retention	Transition (move) vs. Expiration (delete)

Exam Tips:

- SSE-C = You provide key with EVERY PUT request
- Macie ≠ GuardDuty (Macie = data, GuardDuty = threats)
- Config = "What did the resource look like at 2 PM yesterday?"
- Audit Manager = "Show me proof we're compliant"



SAA-C03

53

Module 1 - Design Secure Architectures – Complete Summary

- **Section 1.1: Securing Access**

- IAM Users, Groups, Roles, Policies
- Least Privilege Principle
- AWS Organizations + SCPs
- Control Tower
- Federation (Identity Center)

- **Section 1.2: Securing Workloads**

- VPC, Subnets, Route Tables
- Security Groups (stateful) vs. NACLs (stateless)
- NAT Gateway (managed) vs. NAT Instance
- WAF (Layer 7), Shield (DDoS), Firewall Manager
- VPN (fast, internet), Direct Connect (dedicated, private)
- PrivateLink (Gateway Endpoint = free for S3)
- ACM (free certs), Secrets Manager

- **Section 1.3: Data Security**

- Encryption at Rest (SSE-S3, SSE-KMS, SSE-C)
- KMS (key management, \$1/month per CMK)
- Encryption in Transit (TLS, bucket policy)
- Macie (PII detection in S3)
- Config (compliance monitoring)
- Audit Manager (evidence collection)
- S3 Lifecycle (transition vs. expiration)



SAA-C03

54



55